

Introdução a Auditoria de Sistemas

Sprint - 3

Alunos:

Caio Souza

Julio Cezar

Lucas Miranda

Lucas Papellas

Victor Merlling

Métricas e Auditoria de Software: Normas e Frameworks

1. Introdução

A auditoria de software tem como objetivo avaliar processos, produtos e controles relacionados ao desenvolvimento e manutenção de sistemas.

As métricas de software auxiliam na tomada de decisão, permitindo medir qualidade, produtividade, confiabilidade, custos, riscos e evolução dos projetos.

2. Normas importantes

ISO/IEC 25010 - Modelo de Qualidade de Software

A ISO/IEC 25010 define um modelo de qualidade para produtos de software e sistemas. Ela estabelece características que podem ser utilizadas para especificação, medição e avaliação da qualidade de software, incluindo aspectos como adequação funcional, desempenho, segurança, compatibilidade, usabilidade, confiabilidade e manutenibilidade.

ISO/IEC 12207 - Processos do ciclo de vida de software

A norma ISO/IEC 12207 descreve processos e atividades envolvidos durante o ciclo de vida do software, servindo como referência para desenvolvimento, operação, manutenção e melhoria de processos.

ISO/IEC 27001 - Gestão de Segurança da Informação

A ISO/IEC 27001 estabelece requisitos para implantação de um Sistema de Gestão de Segurança da Informação (SGSI).

Em auditorias de software, é utilizada para verificar controles relacionados à proteção de dados, gestão de riscos e segurança.

3. Frameworks utilizados em auditoria e melhoria de processos

CMMI (Capability Maturity Model Integration)

O CMMI é um modelo de melhoria de processos que avalia a maturidade das organizações no desenvolvimento e gerenciamento de software.

Ele busca tornar processos mais previsíveis, controlados e eficientes.

COBIT

O COBIT é um framework de governança e gestão de tecnologia da informação.

Ele auxilia auditorias avaliando alinhamento entre TI e objetivos organizacionais, controles, riscos e desempenho.

ITIL

O ITIL é um conjunto de boas práticas para gerenciamento de serviços de TI. É utilizado principalmente em auditorias relacionadas à operação, suporte e entrega de serviços tecnológicos.

4. Métricas utilizadas em auditoria de software

- Complexidade ciclomática: mede a complexidade lógica do código.
- Quantidade de defeitos: avalia qualidade e estabilidade do software.
- Cobertura de testes: indica o percentual do sistema validado por testes automatizados.
- Pontos de função: mede tamanho funcional do software.
- Tempo de resolução de incidentes: avalia eficiência operacional.

5. Relação entre métricas e auditoria

A auditoria utiliza métricas para gerar evidências objetivas sobre a qualidade do software e dos processos.

Com indicadores bem definidos, é possível identificar falhas, riscos e oportunidades de melhoria contínua.

Referências Bibliográficas

ISO. ISO/IEC 25010:2023 - Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — Product quality model.

ISO. ISO/IEC 12207 - Systems and software engineering — Software life cycle processes.

ISO. ISO/IEC 27001 - Information security management systems.

CMMI Institute. Capability Maturity Model Integration (CMMI) for process improvement.

ISACA. COBIT Framework: Governance and Management Objectives.

AXELOS. ITIL Foundation: IT Service Management.

PRESSMAN, Roger S.; MAXIM, Bruce R. Engenharia de Software: Uma Abordagem Profissional.

SOMMERVILLE, Ian. Engenharia de Software.